HSLU Lucerne University of Applied Sciences and Arts

Product Security Lifecycle - Secure Development 2

SPREN
Alex Diekmann



Information Technology
October 2, 2026

FH Zentralschweiz

What you will learn

SPREN1

- **Understand** the difference between **Product Cyber Security** and Information Security
- **Explain** to Management and Developers **why** Product Security is essential
- Know and **apply relevant** Laws, Regulations and **Standards** for specific target markets
- **Build and integrate an SDLC** for Product Security purpose based on relevant standards
- How to do **Product Security Risk Management**
- How to deal with Mergers & Acquisitions from the Product Security perspective

SPREN2

- **Vulnerability Management** & **Incident Handling** for Products
- How to **share Vulnerability & Threat Information**
- How to **deal with Customers** and
- How to ensure **Supply Chain Security**
- **Applying the learnings** to a WIPRO project
- **Presenting findings**, selling measures

Other lectures

- Microsoft SDL
- Threat Modeling with STRIDE / DREAD
- Requirements Management

➢ **SPRG**

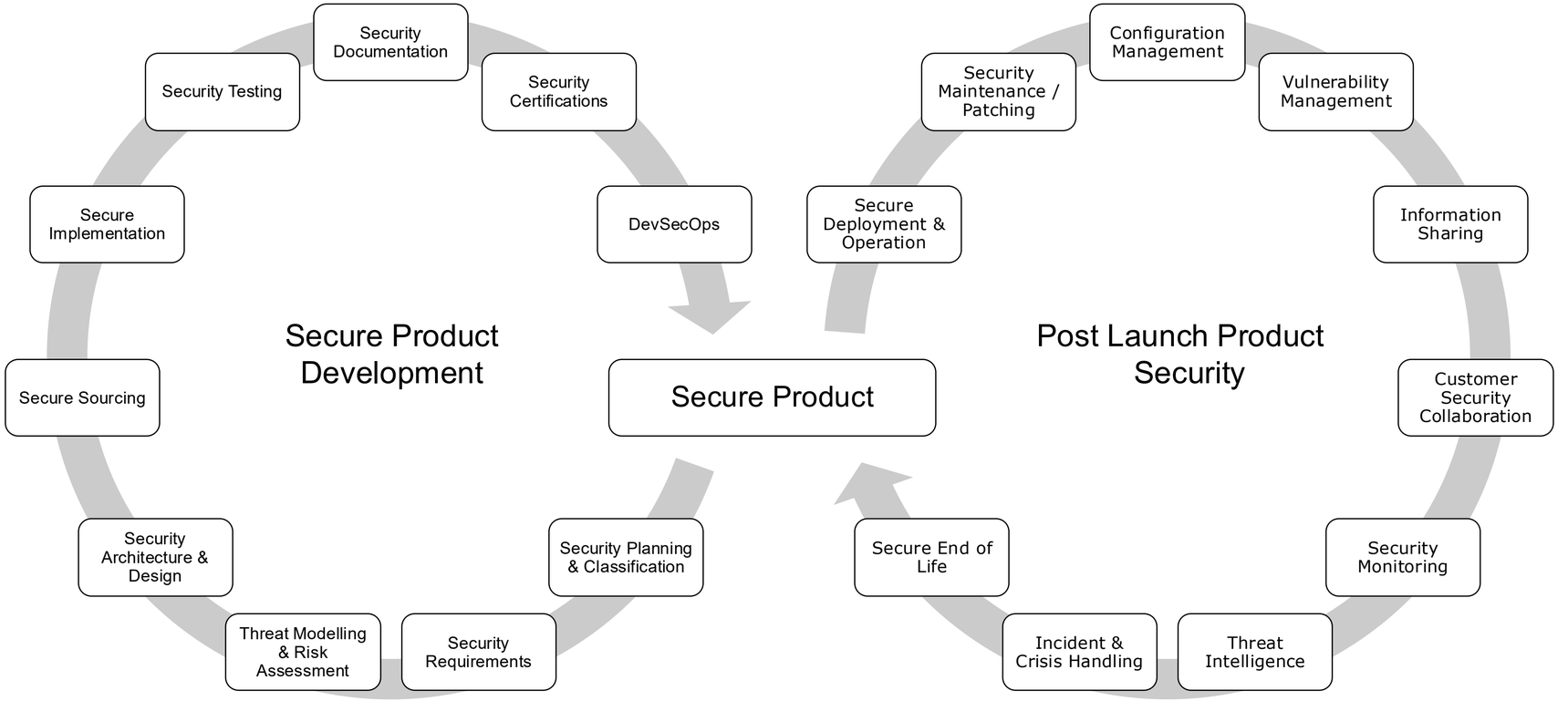
- Hardware Security & Pentesting

➢ **IoT Security**

- Safety Risk Management

➢ **Advanced Risk Management**

Product Cybersecurity Lifecycle



Cyber Security Management System(s)

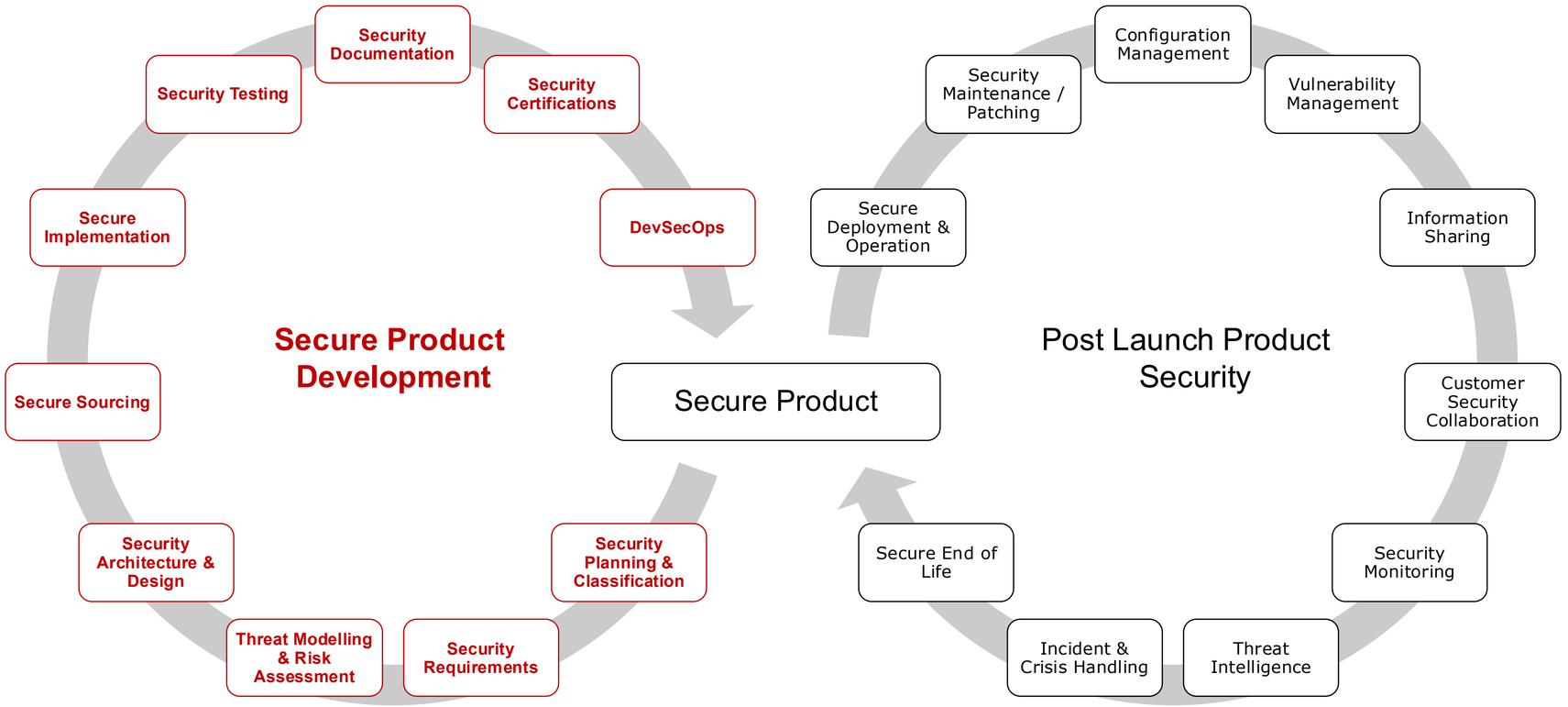
Development & Production Security

Security Risk Management

Organization, Culture, Awareness & Training

Supply Chain Security

Product Cybersecurity Lifecycle



Cyber Security Management System(s)

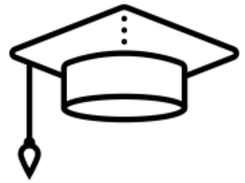
Development & Production Security

Security Risk Management

Organization, Culture, Awareness & Training

Supply Chain Security

Recap / Quiz



1. What motivates companies the most to deal with Product Security?

a) Vulnerabilities & Incidents

b) Laws & Regulations

c) Security Standards

d) Customer Satisfaction

2. What's a key difference between Product Security and Information Security

a) Need for patching

b) Product / System Lifespan

c) Need for testing

d) Overall complexity

3. Which of the following Standards is least relevant for product security?

a) ISO 21434

b) IEC 62443

c) Common Criteria

d) ISO 22316

1. Security Planning & Classification

Goal

- **Classify** criticality of the product to **determine applicable laws & target security level**
- **Plan** and prepare for the necessary cybersecurity **activities & deliverables**
- Plan **enough time** and **resources** to complete the activities

Deliverables

- Classified product / components
- Cybersecurity Plan, including
  - Activity & Deliverable List
  - Roles & Responsibilities
  - Project & Ressource plan

Prerequisites

- Management Commitment
- Product Description & Target Markets
- Classification Scheme
- Product (Security) Inventory

Responsibilities

Responsible:	Project Lead
Accountable:	Product Owner
Supporting:	Product Security
Consulted:	Architect / Scrum Master
Informed:	Product Team

1. Collect Information → 2. Identify Laws, Reg. & Std. → 3. Classify Product(s) → 4. Prepare Cybersecurity Plan → 5. Update Security Inventory

- Market-specific criticality indicators
- Simple Classification Scheme
- Integrate with Project Planning

- Unclear roles & responsibilities
- Unjustified tailoring
- Lack of buffers in planning

CRA Classification Levels

	Default	Important (I)	Important (II)	Critical
Description	**General products** not specifically listed in Annex III or IV (approx. 90% of the market).	**Products with** a significant digital **security component**.	**Products with higher risks**, often used in professional environments.	Products with a **critical security function** whose failure poses high risks, such as in infrastructure, utilities, or finance.
Examples	• IoT **consumer products** (e.g., smart toasters, connected refrigerators), • Software (e.g. consumer games, educational **software**, digital toys)	• **IAM systems** (e.g. Password managers, access control systems, biometric readers) • **Network & Software** (e.g. Browsers, VPNs, antivirus software, email clients). • **Hardware/IoT** (e.g. Smart home door locks/cameras, wearable health trackers)	• **Infrastructure** (e.g. Operating systems (desktop/mobile), hypervisors, container runtime systems) • **Security Tools** (e.g. Firewalls, network management systems, intrusion detection systems) • **Industrial/Physical** (e.g. Industrial Control Systems (PLC), Tamper-resistant microprocessors.)	• **Security Hardware** (e.g. Hardware Security Modules (HSMs), smartcards, secure elements) • **Network** (e.g. Smart meter gateways, industrial IoT gateways) • **Special categories** (e.g. Secure payment terminals, tachographs.)
Conformity Assessment for CE Marking	➢ **Self Assessment**	➢ Self Assessment if **Harmonized Norm** is followed (audited!)	➢ **Mandatory third-party assessment**	➢ Mandatory third-party assessment; may require **European Cybersecurity Certification (EUCC)**

➢ CRA Implementation Regulation (2025/2392) with clarification on covered products

Example: IEC 62443 Security Level

- Determined per component / product
- Define how much protection is required
- Used to tailor the controls of IEC 62443-4-2

SL 0:
- No special requirement or protection required.

SL 1:
- Protection against unintentional or accidental misuse.

SL 2:
- Protection against intentional misuse by simple means with few resources, general skills and low motivation.

SL 3:
- Protection against intentional misuse by sophisticated means with moderate resources, IACS-specific knowledge and moderate motivation.

SL 4:
- Protection against intentional misuse using sophisticated means with extensive resources, IACS-specific knowledge and high motivation.

Example: ISO21434 Cybersecurity Assurance Levels

- Classify how much effort must be put into securign a component
- CALs influence
  - Risk tolerance
  - Security Testing
  - Independence of assessments
- Idea based on Safety Integrity Levels (SIL)
- Currently optional, may become mandatory in the future

CAL	Description	a) Methods to provide confidence that cybersecurity activities are performed with appropriate rigour	b) Methods to provide confidence that unmanaged vulnerabilities do not remain	c) Independence scheme to provide confidence that the cybersecurity activities performed are appropriate
CAL1	Low to moderate cybersecurity assurance is required	Requirement based testing	Activities such as analysis and/or testing to search for vulnerabilities based on known information	Not needed
CAL2	Moderate cybersecurity assurance is required			Cybersecurity assessments are carried out by a different person than the originator
CAL3	Moderate to high cybersecurity assurance is required	All interactions between components are tested	Activities such as analysis and/or testing to search for vulnerabilities by exploratory methods	Cybersecurity assessments are carried out by a person in a different team than the originator
CAL4	High cybersecurity assurance is required	All combinations of interactions between components are tested		Cybersecurity assessments are carried out by a person who is independent regarding management, resources and release authority from the originating department

Cyber Security Plan

- Captures all relevant security activities
- Captures justification for deliverable tailoring
- Linked with, or integrated in Project Plan
- Kept up-to-date with project changes
- Required for ISO21434, recommended elsewhere

Ensure proper document control

Identify & describe the product

BrieflyExplain the development process

Project plan with activities & deliverables

Clarify who does what

Example Cyber Security Plan

0. Document Information
(e.g. ID, Owner & Approvers, Effective Date, Review Cycle, Version History)

1. Overview / Scope
1. Product Information
2. Applicable Laws, Standards
3. Classification & Certification Requirements

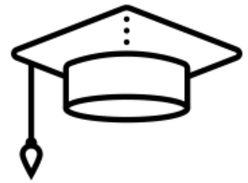
2. Secure Development Process
1. *Process overview*
2. *Process steps, quality / security gates & deliverables*
3. *Integration with Product Development Processes*

3. Cybersecurity Activities
1. *Deliverables for the project*
2. *Tailoring / re-use of deliverables*
3. *Time & Ressource Planning*
4. *Post-Launch activities*

4. Responsibilities
1. *Project Team*
2. *Stakeholders*
3. *Suppliers*
4. *Customers*

5. Definitions, References

Security Classification - Exercise



You are supposed to develop a security classification scheme for a medical device manufacturer.

What factors would you consider when building the scales?

The scheme should have classification scales for

- Confidentiality
- Integrity
- Availability
- Business Criticality

Example: Product Classification Scheme – Medical Devices

	Confidentiality	Integrity	Availability	Business Impact
High	Product stores personal Medical Data	Manipulation of product data causes safety impact	Product breakdown causes safety impact	Strategic Product, Expected revenue > 500m
Medium	Product includes confidential data such as credentials	Manipulation of product data causes treatment issues	Product breakdown causes delayed treatment	Profitable product, expected revenue > 100m
Low	Product only includes public data	Manipulation of product data causes minor inconvenience	Product breakdown causes minor inconvenience	Supporting product, expected revenue < 100m

2. Security Requirements

Goal

➢ Identify and prioritize applicable internal and external security requirements, and translate them into actionable technical requirements

Deliverables

- Product Security Requirements documented, approved and traced
- **S.M.A.R.T.** Technical Security Requirements
- Use Cases
- Backlog items > Sprint planning

Prerequisites

- Product Classification
- Market Requirements
- Security Standards / Control Baselines

Responsibilities

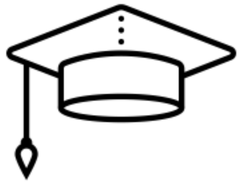
Responsible:	Requirements Mgr.
Accountable:	Product Owner
Supporting:	Project Lead / Product Security
Consulted:	Architect / Developer
Informed:	Scrum Master

1. Elaborate External Requirements → 2. Elaborate Internal Requirements → 3. Prioritize Requirements → 4. Document & Sign Off → 5. Break Down & Refine

- S.M.A.R.T requirements
- Documented rationales
- Field staff consulted for input

- Sec. expert not involved
- Generic requirements
- Lack of review

Exercise: Security Requirements



The Good

- Product Req.: *"The System shall be certified in accordance with Common Criteria Protection profile pp0084, in order to fulfill MNO certification requirements"*
- Technical Req.: *"The Control Unit Windows Firewall shall block all inbound and outbound network connections on all ethernet and wifi interfaces, except for the following connections:*
  TCP Port 443 inbound from ip 10.123.12.3"

The Bad

- Product Req.: *"Relevant components in the product shall be FIPS certification ready"*
- Technical Req.: *"All network interfaces shall be protected by firewalls"*

The Ugly

- Product Req.: *"The product shall provide state-of-the-art security"*
- Technical Req.: *"The system shall be hardened"*

3. Threat Analysis & Risk Assessment

Goal

- Identify and mitigate security risks associated with the product design
- Ensure proactive risk treatment
- Ensure residual risks remain acceptable

Deliverables

- Threat Model
- Risk Assessment
- Mitigation Plan
- Acceptance & Monitoring

Prerequisites

- Risk Team
- Methodology & Rating Scheme
- Risk Catalogues
- Threat Modeling / Risk Management Tools

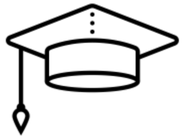
Responsibilities

Responsible:	Product Security
Accountable:	Product Owner
Supporting:	Project Lead / Architect /
Consulted:	Developer
Informed:	Req. Manager / Test Manager

1. Prepare Tools, Team and Input → 2. Identify Threats → 3. Assess Risks → 4. Treat Risks → 5. Report, Monitor & Regularly Review Risks

- Mode detail in “Security Risk Management Basics I & II” lecture

Time to rest



10 Min Break

4. Security Architecture & Design

Goal

- Fulfill relevant security quality attributes in the product's architecture & ensure security controls are designed properly in detail

Deliverables

- Security Quality attributes
- High-level security architecture
- Detailed Security Design
- Architecture & Design Review

Prerequisites

- High-level System Architecture
- Product Security Requirements
- Threat Model

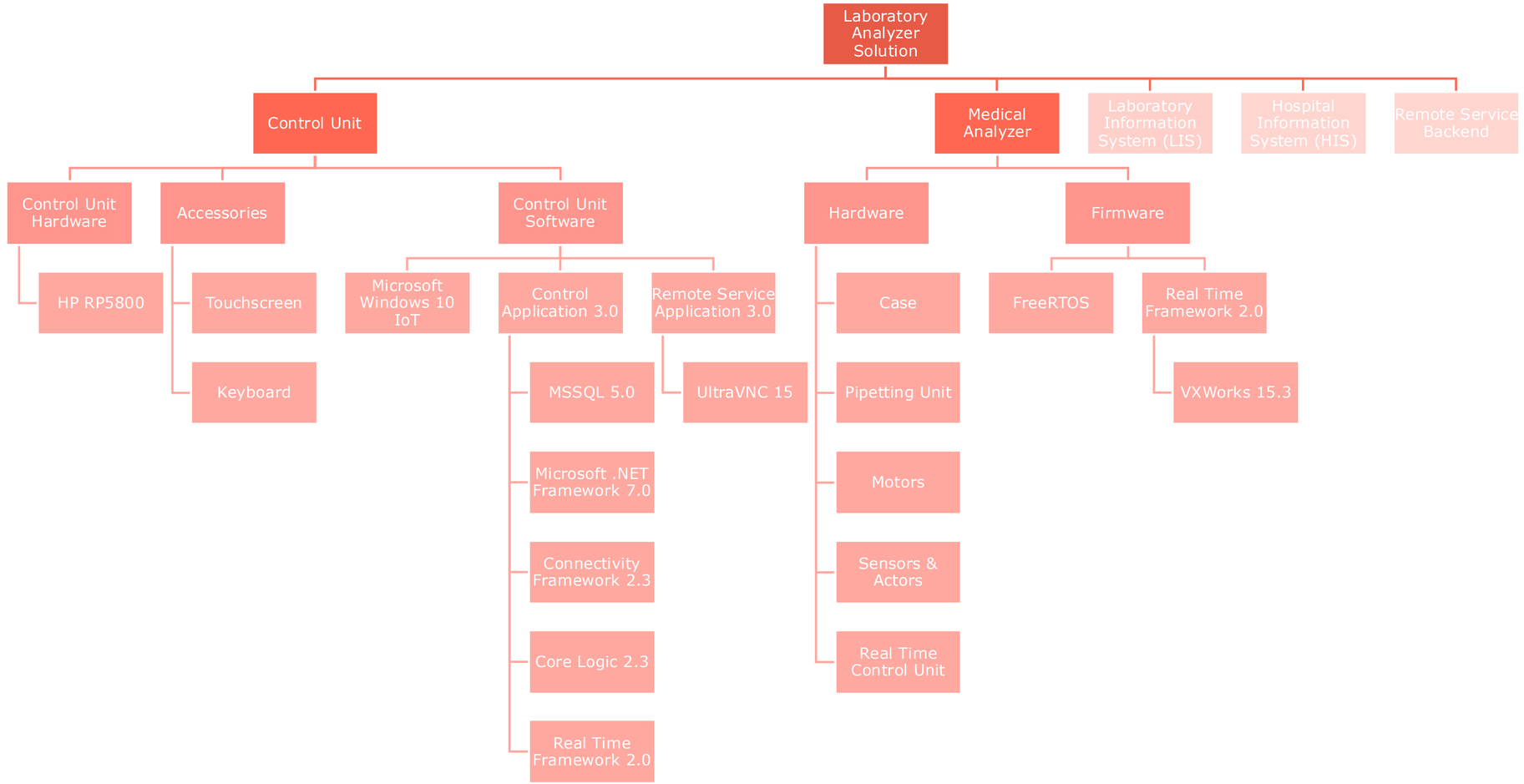
Responsibilities

Responsible:	Architect
Accountable:	Product Owner
Supporting:	Developer / Product Security
Consulted:	Project Manager
Informed:	Req. Manager

1. Security Quality Attributes → 2. Derive Requirements → 3. Security Architecture → 4. Design Decisions & Trade-offs → 5. Architecture & Design Review

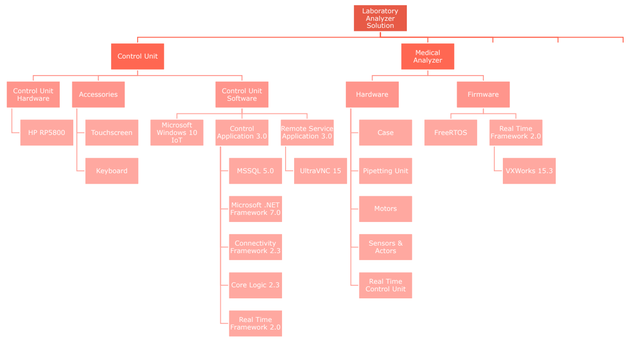
- More detail in "Security Architecture & Design" lectures

Exercise: What’s this diagram useful for?



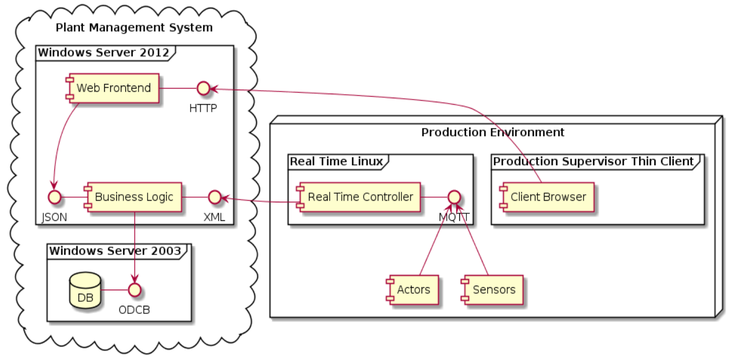
Architecture Views

System Decomposition



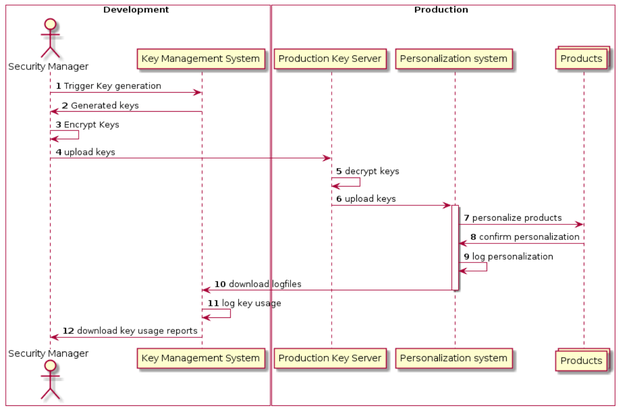
- Components & sub-components in the system
- Basis for Configuration Data & classification
- Security use cases
  - Threat Modeling
  - Vulnerability Management

Deployment View



- Components & Interfaces
- Security use-cases
  - Threat Modeling
  - Mitigation planning

Data Flow Diagrams



- Flow of individual data items between system components
- Security use-cases

5. Secure Sourcing

Goal

- Ensure externally sourced components fulfill the security requirements
- Ensure sourced components are integrated securely

Deliverables

- Security criteria for provider selection
- Security Requirements for outsourced development
- Security specifications for components
- Acceptance tests for sourced components

Prerequisites

- Security Standards for component suppliers / development partners
- Supply Chain Security Processes (More details in Lecure "Supply Chain Security" in SPREN2)

Responsibilities

Responsible:	Project Lead
Accountable:	Product Owner
Supporting:	Sourcing / Product Security
Consulted:	Architect

1. Define Requirements → 2. Select Provider → 3. Source Components → 4. Ensure secure delivery → 5. Acceptance Testing

- Pre-defined selection guidelines
- Contract templates
- Integration with Test Plans

- Undocumented 3rd party components
- Stakeholders not involved in supplier selection
- Missing security requirements in contracts

Secure Sourcing – What to look for

Commercial components

- Security Certifications
- Known Vulnerabilities / CVEs
- Patch Frequency
- Responsible Disclosure Policy
- Current and past hacking
  - Conference Talks
  - Blog Posts
  - Articles
  - Videos

Open Source Components

- Active vs. legacy project
- Known vulnerabilities / CVEs
- Long-term-support versions
- Documentation of the Source code

Cloud Services

- ISO27001 certificate / SOC reports etc.
- Size of the cloud provider
- Location(s) of hosting
- Past Incidents / Breaches

Outsourced Development – What to ensure

Provider Selection

- Know How
- Reputation
- Other customers
- Security Certifications
- Track record of (Security) support
- Access to source code / escrow
- Adaption to customer policies & processes

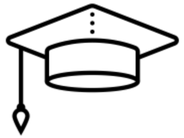
Outsourcing development center

- Location(s)
- Information Security (DLP!)
- Development Environment Architecture
- Physical Security
- Tenant segregation
- Training & Awareness
- Right to Audit

Provided Components

- Secure Coding
- Security Testing / Pentests
- Stability
- Maintainability

Quiz



1. Which test case does not ensure acceptability of a commercial off-the-shelf (COTS) software package?

a) Integrity of the SW package

b) Malware Check

c) Vulnerability Scan

d) Secure Coding check

2. Which of the following helps identify secure cloud providers?

a) Breach notifications

b) SOC 2 Reports

c) Conference Talks

d) Vulnerability Scans

3. How to prevent data leaks in an ODC?

a) Conducting regular awareness training

b) Demanding up-to-date security certificates

c) Development System Architecture prevents local download of source code

d) Executing regular on-site audits

6. Secure Implementation

Goal

➢ Ensure that the system and security controls are developed in a secure manner.

Deliverables

- Secure Coding
- Automated Testing
- Source Code Reviews
- Acceptance Testing (external components)
- Secure Crypto Handling

Prerequisites

- Secure Coding Standards / Best Practices
- Build / test automation tools
- Security Testing Tools
  - SAST & DAST tools
  - SCA Tools
- Secure Development Environment

Responsibilities

Responsible:	Developer
Accountable:	Product Owner
Supporting:	Architect / Project Lead
Consulted:	Product Security
Informed:	Scrum Master

1. Define Standards → 2. Prepare Toolchain → 3. Support Implementation → 4. Review Implementation

- Standards cover relevant languages
- Include in outsourcing contracts
- Automate where possible



- Pass with errors
- Lack of training
- Lack of experts

Secure Implementation – AI & Vibe Coding

Use Cases

- Code generation & refacturing
- Test automation & debugging
- Code review & vulnerability detection
- Developer training
- AI-assisted reverse engineering (AIARE)

Security Risks

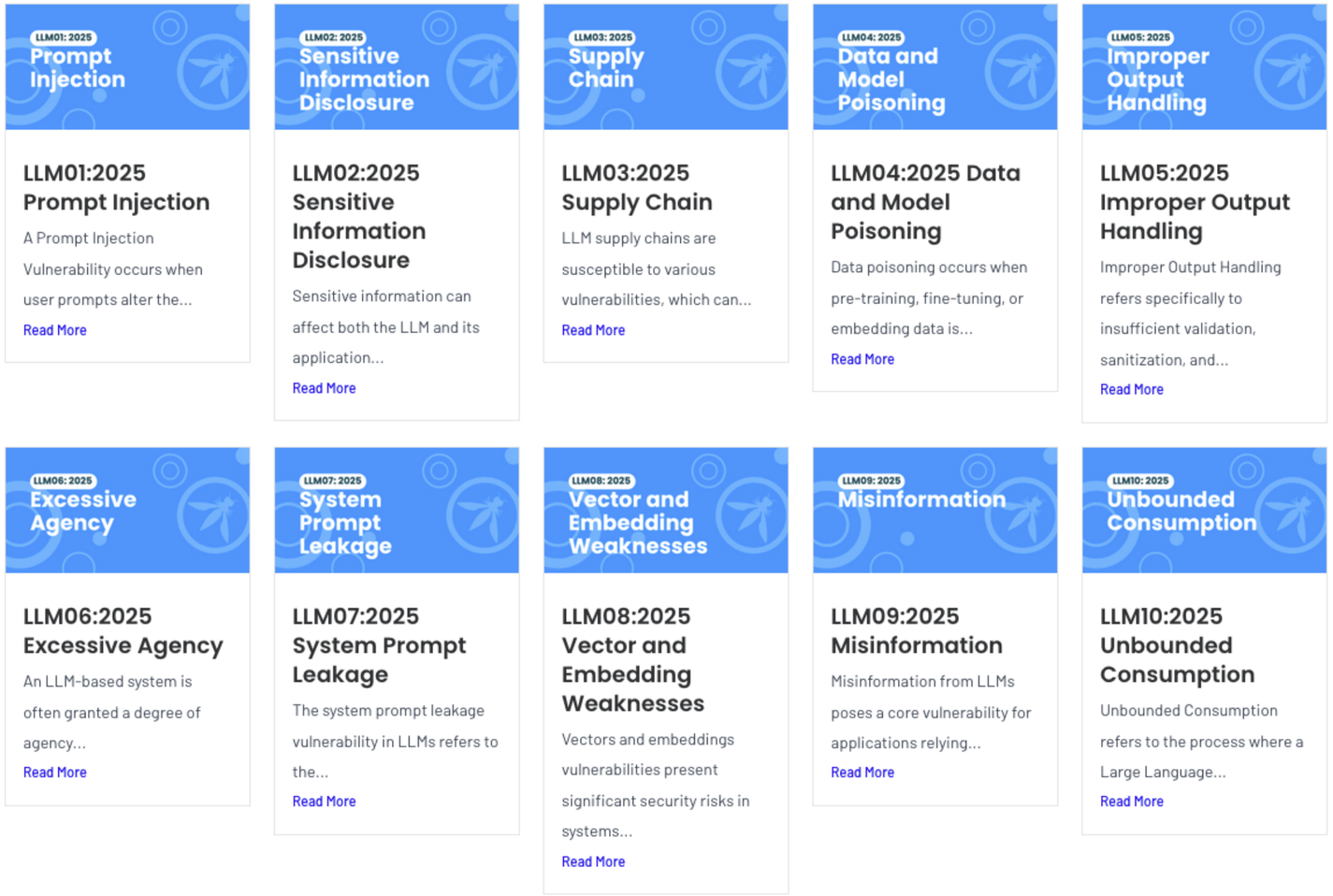
- Vulnerable Code
- Broken / hallucinated Code
- Complex architectures, many sub-libraries
- Leaked IP / Secrets
- License violations
- Skill erosion

Measures

- Discover and assess all AI use
- Use AI as a tool, not as a coworker
- Manual verification
- Test everything (incl. classic SAST/DAST)
- Secret scanners / license scanning
- AI monitoring
- DLP
- Secure Coding Trainings

OWASP Top 10 for LLMs

- List of relevant security threats for LLMs
- Outcome of the OWASP GenAI Security Project
- Maintained since 2023
- Current List on genai.owasp.org



Secure Implementation - Tools

Static Code Analysis (SAST)

- Ensure Secure Coding Guidelines are followed in the source code > “static”
- Linter
- SonarQube
- Bandit
- Git-secrets
- …

Dynamic Code Analysis (DAST)

- Test automated vulnerability exploitation on the running system > «dynamic»
- OpenVAS
- OWASP ZAP
- Burp
- SSLScan
- …

Software Composition Analysis Tools (SCA)

- Find vulnerable components in the system decomposition
- Debscan
- OWASP dependency check
- Snyk
- Black Duck
- …

7. Security Testing

Goal

- Ensure that security controls work, remain in tact when all system components are integrated
- Ensure that the complete system is tested internally or externally for vulnerabilities.

Deliverables

- Security Testing Plan
- Security Test Cases
- Integration & Regression Testing
- Vulnerability Analysis / Pentesting
- Security Testing Report

Prerequisites

- Testable Security Requirements
- Threat Model
- Test Infrastructure
- Security Testing Tools
- Experts

Responsibilities

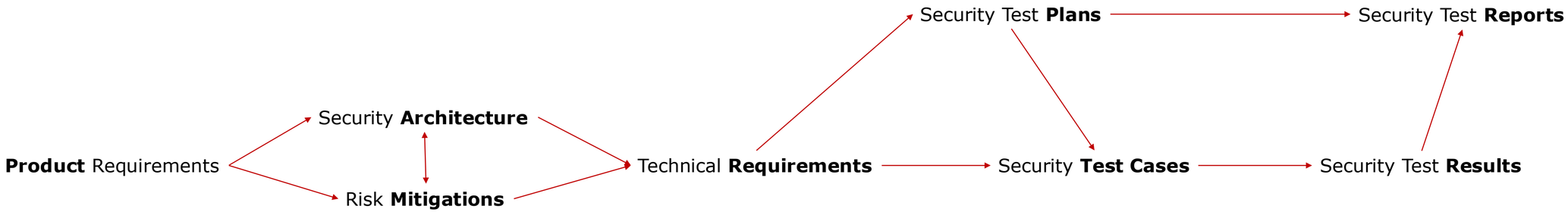
Responsible:	Test Manager
Accountable:	Product Owner
Supporting:	Product Security / Developer
Consulted:	Req. Manager / Architect
Informed:	Scrum Master / Project Lead

1. Plan Security Testing → 2. Create Test Cases / Test Setup → 3. Support Testing → 4. Testing Report → 5. Follow up on findings

- Internal functional & sanity testing
- Involve externals
- Whitebox testing

- Untested requirements
- Acceptance of failures
- No follow up

Security Testing - Traceability

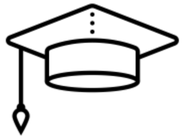


- Establishes the **link** between **requirements** and **test results**
- **Prooves** that **requirements** actually got **implemented**, and risk **mitigations** actually **work** as specified
- **Required** by nearly all secure development process **standards** (because good development practice)

Traceability Tools

- Jama
- SystemWeaver
- Jira
- HP ALM
- Good Old Word & Excel

Exercise: Security Test Cases



The Good

- Req.: *“The Control Unit Windows Firewall shall by block all inbound and outbound network connections”*
- Test Case.: *“Verify that the Windows Firewall blocks all inbound and outbound network connections by default”*
- Steps.: *“Open the windows firewall advanced settings, public profile, […], verify the default settings for inbound and outbound connections”*
- Excepted Outcome*: ”Settings are set to “Block All””*

The Bad

- Req.: “The System shall be hardened in accordance with standard XYZ”
- Test Case.: *“Verify System Hardening”*
- Excepted Outcome*: “Settings shall be as recommended by standard XYZ”*

The Ugly

- Test Case.: “Verify that Encryption Works”
- Excepted Outcome: “Encryption Works as expected”

8. Security Documentation

Goal

- Document relevant security aspects for installation, operation and use, outline the security concept and known issues, and provide relevant documents for security certification

Deliverables

- Installation and Operation Guidance
- Security User Guidance
- Release Notes / Known Issues / Risks
- Security Concept & Intended Use
- Certification documentation
- Software Bill of Materials (SBOM)

Prerequisites

- Templates
- Documented Security Architecture & Features
- Known Issues Lists
- Website / Customer Portal to publish

Responsibilities

Responsible:	Project Lead
Accountable:	Product Owner
Supporting:	Developer / Marketing & Coms.
Consulted:	Product Security

1. Draft → 2. Review → 3. Signoff → 4. Publish

- Broad review
- Clear language
- Defined glossary

- Too much detail
- Hiding issues
- Legalistic language

9. Security Certification

Goal

➢ Products receive Security Certifications required or desired for the target market(s)

Deliverables

- Certification deliverables
- Provider selected
- Gap Analysis
- Certification
- Declaration of Conformity (CE)

Prerequisites

- Management Commitment
- Compliant Development Process
- Security Management
- Security Experts
- Security Culture

Responsibilities

Responsible:	Project Lead
Accountable:	Product Owner
Supporting:	Product Security / Architect
Consulted:	Req. Manager / Test Manager

Select Certification Partner → Create Certification Deliverables → Pre-Audit / Gap Closure → Certification Request → Certification Audit

- Choose certification partner wisely
- Get external experts on board
- Get multiple opinions

- "Retrofitting" certifications
- Building "special" environments
- Underestimating stringency

10. DevSecOps

Goal

- Speed up secure development by automating security testing and configuration in the CI/CD Pipeline

Deliverables

- DevSecOps pipeline, including automated
  - SAST / DAST / SCA tools / Vulnerability Scanning
  - Security configuration / Hardening
  - Separation Dev / Staging / Prod with approval step(s)

Prerequisites

- DevOps
- CI/CD Pipeline
- SAST / DAST / SCA Tools
- Coding Guidelines
- Hardening specification

Responsibilities

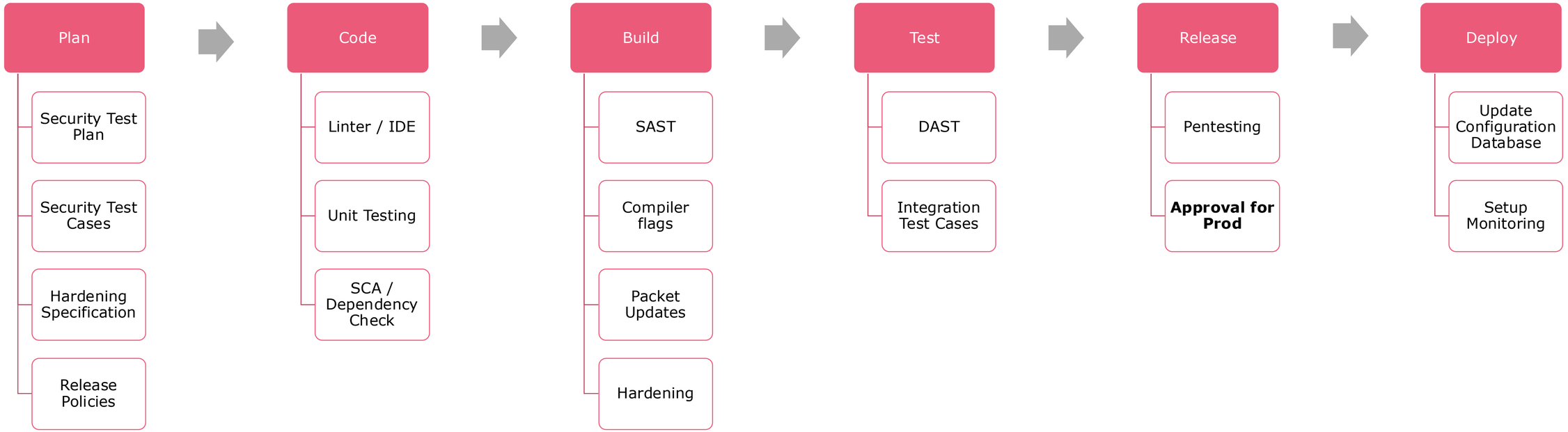
Responsible:	Developer
Accountable:	Product Owner
Supporting:	Architect / Build Master / Test Manager
Consulted:	Product Security
Informed:	Scrum Master

1 Plan the Pipeline → 2 Prepare Testing Tools → 3 Set up the DevSecOps Pipeline → 4 Test the Pipeline → 5 Train Developers / DevOps team

- Integrate Approval Steps
- Infrastructure as Code
- Connect with configuration management & monitoring

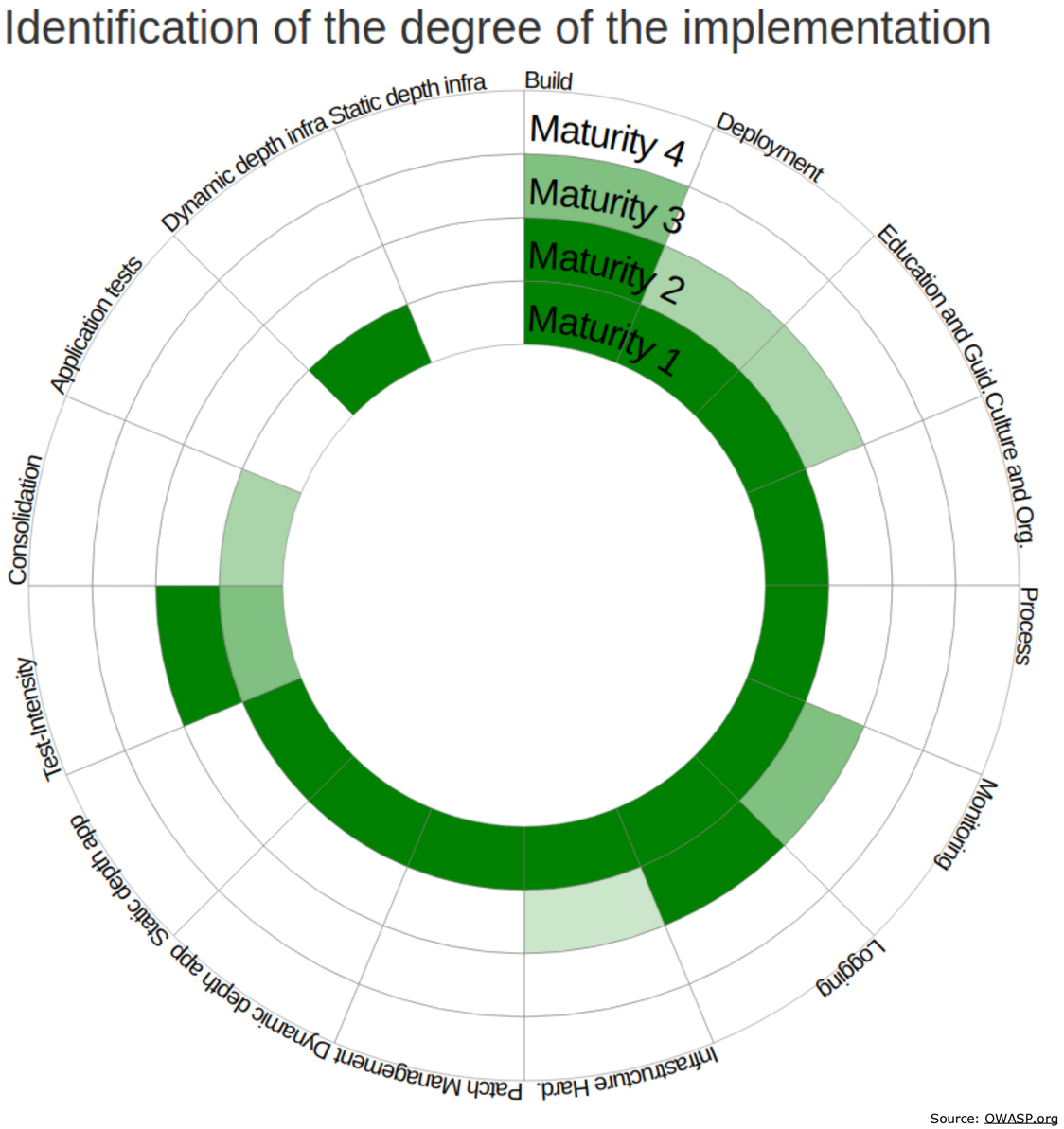
- Allowing merge to prod with coding errors
- Direct deployment to prod

A typical DevSecOps Pipeline



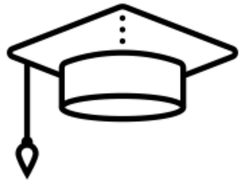
DevSecOps: OWASP DSOMM

- Maturity Model for DevSecOps practices
- Categories of practices
  - Build and Deployment
  - Culture and Organization
  - Implementation
  - Information Gathering
  - Test and Verification
- Source & Specification: https://dsomm.owasp.org/



Source: OWASP.org

Time for questions



?

Contact Details



Alex Diekmann

e-Mail: alexander.diekmann@hslu.ch

Threema: 7SBWM9V7

LinkedIn: https://www.linkedin.com/in/alexdiekmann/

Contents of these slides may not be modified or re-used without prior approval of the author.

This presentation includes icons from the feather framework, which is published under the MIT license, and (where other sources are not specified) uses images from Wikimedia, released under Creative Commons 2.0 License or as Public Domain